



HTTP Host Header Attacks

I. Khái niệm

HTTP Host header là một thành phần thiết yếu trong yêu cầu HTTP/1.1. Khi người dùng truy cập vào một trang web, trình duyệt sẽ gửi một yêu cầu HTTP với Host header chứa tên miền của trang web đó. Điều này giúp xác định chính xác ứng dụng hoặc trang web mà người dùng đang truy cập, đặc biệt quan trọng khi nhiều website hoặc ứng dụng chia sẻ cùng một địa chỉ IP. Điều này xảy ra phổ biến trong các trường hợp:

II. Virtual Hosting:

Một máy chủ có thể lưu trữ nhiều trang web với các tên miền khác nhau, nhưng tất cả đều chia sẻ cùng một địa chỉ IP. Điều này thường thấy trong các dịch vụ đám mây hoặc các giải pháp SaaS, nơi mà các trang web của các tổ chức khác nhau có thể được lưu trữ trên cùng một máy chủ.

III. Định tuyến qua hệ thống trung gian:

Các website có thể được lưu trữ trên các máy chủ backend riêng biệt, nhưng lại sử dụng các hệ thống trung gian như proxy đảo ngược hoặc bộ cân bằng tải (load balancer) để chuyển tiếp yêu cầu. Điều này đặc biệt phổ biến khi sử dụng CDN, nơi tất cả tên miền đều trỏ đến một IP chung của hệ thống trung gian. Trong cả hai trường hợp trên, Host header được sử dụng để xác định chính xác ứng dụng hoặc backend cần chuyển yêu cầu đến.

IV. Tấn công HTTP Host header

Tấn công HTTP Host header khai thác các điểm yếu khi máy chủ xử lý giá trị Host header không an toàn. Nếu một máy chủ tự động tin tưởng vào giá trị của Host header



mà không có biện pháp xác minh, kẻ tấn công có thể sử dụng giá trị này để thay đổi hành vi của máy chủ theo ý muốn. Một số kịch bản tấn công phổ biến:

Host header injection: Là khi giá trị Host header được chỉnh sửa để chèn các payload gây hại, có thể tác động đến server hoặc các hệ thống phụ trợ.

Web cache poisoning: Kẻ tấn công lợi dụng Host header để gửi các yêu cầu độc hại nhằm đầu độc bộ nhớ cache của web, khiến người dùng khác nhận phải dữ liệu không chính xác hoặc độc hại.

Lỗi logic ứng dụng: Trong một số trường hợp, máy chủ dùng giá trị của Host header để tạo các URL tuyệt đối, chẳng hạn như trong các email kích hoạt hoặc đặt lại mật khẩu. Điều này có thể bị lạm dụng để gửi người dùng đến các tên miền giả mạo hoặc tấn công ứng dụng.

SSRF dựa trên định tuyến: Khi các hệ thống backend không phân biệt rõ giữa yêu cầu nội bộ và yêu cầu từ bên ngoài, kẻ tấn công có thể sử dụng Host header để chuyển hướng đến các hệ thống nội bộ, từ đó khai thác các dịch vụ không bảo mật.

V. Nguyên nhân gây ra lỗ hổng HTTP Host header

Lỗ hổng HTTP Host header thường xuất phát từ giả định sai lầm rằng Host header là không thể bị người dùng thay đổi. Một số ứng dụng và máy chủ có thể không xử lý kỹ lưỡng giá trị Host header hoặc không lọc các giá trị nguy hiểm khi nhận yêu cầu từ bên ngoài, dẫn đến lỗ hổng bảo mật. Hơn nữa, nhiều tổ chức không xem xét các header phụ trợ như X-Forwarded-Host, vốn thường được hỗ trợ mặc định, dẫn đến nguy cơ bị ghi đè Host header.

Một số lỗ hổng không phải do mã nguồn không an toàn, mà do cấu hình sai hoặc thiếu hiểu biết về cách các thành phần tương tác trong hệ thống phức tạp. Việc sử dụng các công nghệ và dịch vụ bên thứ ba, chẳng hạn như dịch vụ đám mây hoặc các hệ thống CDN, có thể dẫn đến các cấu hình không an toàn nếu không được điều chỉnh cẩn thận.



VI. Biện pháp phòng ngừa tấn công HTTP Host header

Để ngăn ngừa tấn công HTTP Host header, có một số biện pháp bảo mật như sau:

Sử dụng URL tương đối: Tránh sử dụng URL tuyệt đối trong mã nguồn nếu không cần thiết, vì URL tương đối không dựa vào giá trị của Host header. Điều này giúp ngăn chặn các cuộc tấn công như web cache poisoning.

Bảo vệ URL tuyệt đối: Nếu bắt buộc phải sử dụng URL tuyệt đối, giá trị tên miền nên được thiết lập thủ công trong tập tin cấu hình và tham chiếu đến nó thay vì Host header. Điều này giúp tránh các cuộc tấn công như password reset poisoning.

Xác thực Host header: Nếu cần sử dụng Host header, luôn xác thực giá trị của nó dựa trên danh sách tên miền hợp lệ. Một số framework như Django cung cấp tùy chọn ALLOWED_HOSTS trong tệp cấu hình để chỉ định các tên miền hợp lệ. Cách này giúp giảm thiểu nguy cơ tấn công injection qua Host header.

Tránh hỗ trợ các header ghi đè Host: Kiểm tra cấu hình máy chủ để không hỗ trợ các header có thể ghi đè giá trị Host header, chẳng hạn như X-Forwarded-Host, vì điều này thường được bật mặc định trong một số môi trường.

Thiết lập danh sách tên miền được phép: Cấu hình bộ cân bằng tải hoặc proxy để chỉ chuyển tiếp yêu cầu đến các tên miền được chỉ định trong danh sách cho phép nhằm ngăn chặn các cuộc tấn công dựa trên định tuyến vào hệ thống nội bộ.

Bảo mật các virtual host nội bộ: Khi sử dụng virtual hosting, cần tránh lưu trữ các trang web và ứng dụng chỉ dùng nội bộ trên cùng một máy chủ với các nội dung công khai. Điều này giúp ngăn chặn kẻ tấn công lợi dụng Host header để truy cập trái phép vào các dịch vụ nội bộ.

Bằng cách áp dụng các biện pháp này, các tổ chức có thể giảm thiểu rủi ro từ các cuộc tấn công qua Host header và bảo vệ cơ sở hạ tầng web tốt hơn.



Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team